

HOME LAB: RED & BLUE TEAM SIMULATION - arsoc00

This project was created to test defensive and offensive security. The entire network infrastructure and the attacks have been simulated locally on virtualized machines.

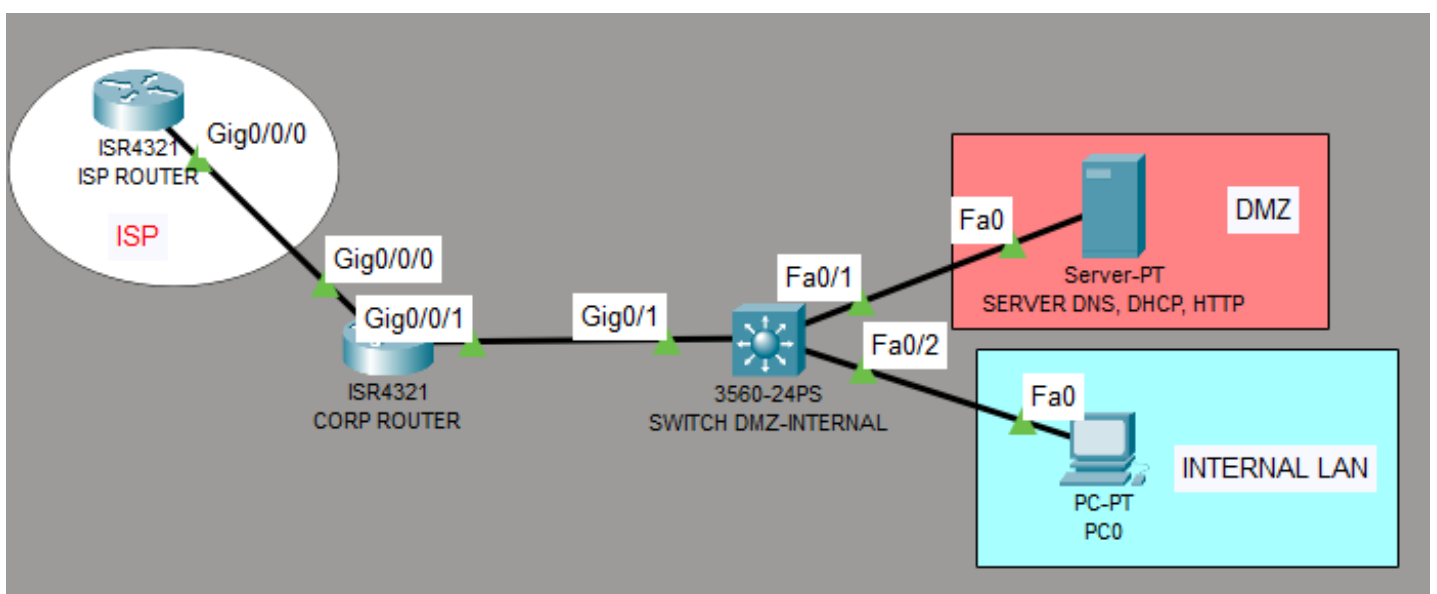
1. INTRODUCTION AND OBJECTIVES

The fictional background of the project is that the company "Corporation" has a server (corp-server) located in a DMZ, on which DHCP, DNS, and HTTP services are installed to support its business operations, as well as an internal LAN for its employees; both are connected to each other via a switch, and the switch connects them to the company's router. The server has a Wazuh agent installed, which is monitored by a computer on the internal LAN that acts as a manager.

The objective is to practice enumeration, intrusion, and privilege escalation techniques in terms of offensive security, as well as log analysis, detection, and hardening in terms of defensive security. It is also designed as a homemade CTF and includes a flag that indicates the success of the attack on the server.

2. NETWORK ARCHITECTURE

We'll begin by explaining the network architecture, created using Cisco Packet Tracer. Here, you can clearly see how the server is located on a network separate from the internal LAN via a switch and how the switch, in turn, connects to the internet via the corporate router. The network components have been configured as if they were operating on a real network, solely for practice purposes. The project itself was carried out using virtual machines on an internal network. The project was carried out using virtual machines on an internal network in VirtualBox.



The network assignment table would look like this:

Device	Interface	IP Address	Subnet mask	Default Gateway
ISP-ROUTER	G0/0/0	10.0.0.1	255.255.255.252	To the Internet
CORP-ROUTER	G0/0/0	10.0.0.2	255.255.255.252	10.0.0.1
	G0/0/1.10	192.168.10.1	255.255.255.0	DMZ Gateway
	G0/0/1.20	192.168.20.1	255.255.255.0	LAN Gateway
SWITCH	VLAN 10 (MGMT)	192.168.10.2	255.255.255.0	192.168.10.1
SERVER	Fa0	192.168.10.10	255.255.255.0	192.168.10.1
PC0	Fa0	192.168.20.10	255.255.255.0	192.168.20.1

3. NETWORK EQUIPMENT CONFIGURATION

ISP ROUTER CONFIGURATION

The only settings configured on the ISP router are the IP address and subnet mask, so that the corporate router can connect.

```
Router>enable
Router#conf t
Enter configuration commands, one per line. End with CNTL/Z.
Router(config)#hostname ISP-ROUTER
ISP-ROUTER(config)#int g0/0/0
ISP-ROUTER(config-if)#ip address 10.0.0.1 255.255.255.252
ISP-ROUTER(config-if)#no shut

ISP-ROUTER(config-if)#
%LINK-5-CHANGED: Interface GigabitEthernet0/0/0, changed state to up

ISP-ROUTER(config-if)#exit
ISP-ROUTER(config)#
```

CORPORATE ROUTER CONFIGURATION

The IP address, subnet mask, and interfaces have been configured on the corporate router, and the "encapsulation dot1Q" command has been used to separate network traffic for each VLAN. Security measures, such as password encryption, have also been implemented, along with passwords for accessing the router's configuration and for remote access.

```

Router>enable
Router#conf t
Enter configuration commands, one per line. End with CNTL/Z.
Router(config)#hostname CORP-ROUTER
CORP-ROUTER(config)#int g0/0/0
CORP-ROUTER(config-if)#ip add 10.0.0.2 255.255.255.252
CORP-ROUTER(config-if)#no shut

CORP-ROUTER(config-if)#
%LINK-5-CHANGED: Interface GigabitEthernet0/0/0, changed state to up

%LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/0/0, changed state to up

CORP-ROUTER(config-if)#exit
CORP-ROUTER(config)#int g0/0/1
CORP-ROUTER(config-if)#no shut

CORP-ROUTER(config-if)#
%LINK-5-CHANGED: Interface GigabitEthernet0/0/1, changed state to up

%LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/0/1, changed state to up

CORP-ROUTER(config-if)#exit
CORP-ROUTER(config)#int g0/0/1 10
CORP-ROUTER(config)#int g0/0/1.10
CORP-ROUTER(config-subif)#
%LINK-3-UPDOWN: Interface GigabitEthernet0/0/1.10, changed state to down

%LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/0/1.10, changed state to up

CORP-ROUTER(config-subif)#enc
CORP-ROUTER(config-subif)#encapsulation dot1Q 10
CORP-ROUTER(config-subif)#ip add 192.168.10.1 255.255.255.0
CORP-ROUTER(config-subif)#exit
CORP-ROUTER(config)#int g0/0/1.20
CORP-ROUTER(config-subif)#
%LINK-3-UPDOWN: Interface GigabitEthernet0/0/1.20, changed state to down

%LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/0/1.20, changed state to up

CORP-ROUTER(config-subif)#encapsulation dot1Q 20
CORP-ROUTER(config-subif)#ip add 192.168.20.1 255.255.255.0
CORP-ROUTER(config-subif)#exit
CORP-ROUTER(config)#ip route 0.0.0.0 0.0.0.0 10.0.0.1
CORP-ROUTER(config)#exit
CORP-ROUTER#

CORP-ROUTER#conf t
Enter configuration commands, one per line. End with CNTL/Z.
CORP-ROUTER(config)#service password-encryption
CORP-ROUTER(config)#enable secret CorpPass2026@
CORP-ROUTER(config)#line con 0
CORP-ROUTER(config-line)#pass ConsolePass2026@
CORP-ROUTER(config-line)#login
CORP-ROUTER(config-line)#exec-timeout 10 0
CORP-ROUTER(config-line)#logging synchronous
CORP-ROUTER(config-line)#exit
CORP-ROUTER(config)#line vty 0 4
CORP-ROUTER(config-line)#pass RmtPass2026@
CORP-ROUTER(config-line)#login
CORP-ROUTER(config-line)#transport input ssh
CORP-ROUTER(config-line)#exit
CORP-ROUTER(config)#

```

CORP-SWITCH CONFIGURATION

The DMZ and internal LAN VLANs have been defined on the switch, and "switchport trunk encapsulation dot1Q" and "switchport mode trunk" have been used to enable data to be sent to each VLAN separately. Security measures were then defined in the same way as on the router.

```
Switch>enable
Switch#conf t
Enter configuration commands, one per line. End with CNTL/Z.
Switch(config)#hostname CORP-SWITCH
CORP-SWITCH(config)#vlan 10
CORP-SWITCH(config-vlan)#name DMZ-SERVER
CORP-SWITCH(config-vlan)#exit
CORP-SWITCH(config)#vlan 20
CORP-SWITCH(config-vlan)#name INTERNAL-LAN
CORP-SWITCH(config-vlan)#exit
CORP-SWITCH(config)#int g0/1
CORP-SWITCH(config-if)#switchport trunk encapsulation dot1q
CORP-SWITCH(config-if)#switchport mode trunk

CORP-SWITCH(config-if)#
%LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/1, changed state to down

%LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/1, changed state to up

CORP-SWITCH(config-if)#exit
CORP-SWITCH(config)#int f0/1
CORP-SWITCH(config-if)#switchport mode access
CORP-SWITCH(config-if)#switchport access vlan 10
CORP-SWITCH(config-if)#exit
CORP-SWITCH(config)#int f0/2
%LINK-3-UPDOWN: Interface FastEthernet0/3, changed state to down

%LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/3, changed state to down

CORP-SWITCH(config-if)#int f0/2
CORP-SWITCH(config-if)#switchport mode access
CORP-SWITCH(config-if)#switchport access vlan 20
CORP-SWITCH(config-if)#exit
CORP-SWITCH(config)#exit
CORP-SWITCH#
%SYS-5-CONFIG_I: Configured from console by console

CORP-SWITCH#conf t
Enter configuration commands, one per line. End with CNTL/Z.
CORP-SWITCH(config)#service password-encryption
CORP-SWITCH(config)#enable secret SwitchPass2026@
CORP-SWITCH(config)#line con 0
CORP-SWITCH(config-line)#pass ConsSwi2026@
CORP-SWITCH(config-line)#login
CORP-SWITCH(config-line)#exec-timeout 10 0
CORP-SWITCH(config-line)#logging synchronous
CORP-SWITCH(config-line)#exit
CORP-SWITCH(config)#line vty 0 15
CORP-SWITCH(config-line)#pass RmtSwi2026@
CORP-SWITCH(config-line)#login
CORP-SWITCH(config-line)#transport input ssh
CORP-SWITCH(config-line)#exit
CORP-SWITCH(config)#exit
CORP-SWITCH#
%SYS-5-CONFIG_I: Configured from console by console

CORP-SWITCH#

CORP-SWITCH#conf t
Enter configuration commands, one per line. End with CNTL/Z.
CORP-SWITCH(config)#int vlan 10
CORP-SWITCH(config-if)#
%LINK-5-CHANGED: Interface Vlan10, changed state to up

%LINEPROTO-5-UPDOWN: Line protocol on Interface Vlan10, changed state to up

CORP-SWITCH(config-if)#ip add 192.168.10.2 255.255.255.0
CORP-SWITCH(config-if)#no shut
CORP-SWITCH(config-if)#exit
CORP-SWITCH(config)#ip default-gateway 192.168.10.1
CORP-SWITCH(config)#exit
CORP-SWITCH#
%SYS-5-CONFIG_I: Configured from console by console

CORP-SWITCH#
```

```

CORP-SWITCH#conf t
Enter configuration commands, one per line. End with CNTL/Z.
CORP-SWITCH(config)#int vlan 20
CORP-SWITCH(config-if)#
%LINK-5-CHANGED: Interface Vlan20, changed state to up

%LINEPROTO-5-UPDOWN: Line protocol on Interface Vlan20, changed state to up

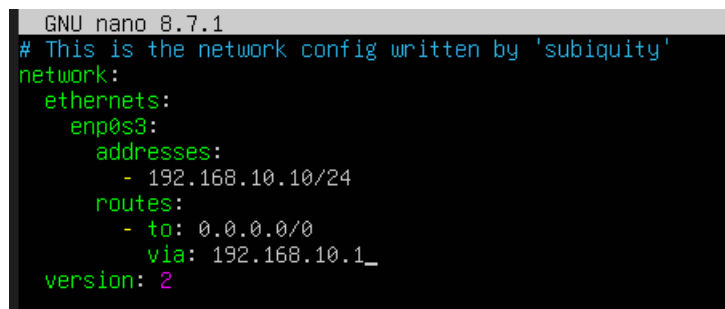
CORP-SWITCH(config-if)#ip add 192.168.20.2 255.255.255.0
CORP-SWITCH(config-if)#no shut
CORP-SWITCH(config-if)#end
CORP-SWITCH#
%SYS-5-CONFIG_I: Configured from console by console

```

4. CORP-SERVER SERVICES INSTALLATION

As previously mentioned, virtual machines in VirtualBox were used to carry out this project; therefore, it would not be necessary to configure the server according to the network topology. However, to follow the same approach, this section explains how the network and DHCP would be configured if such topology existed.

I chose Ubuntu Server version 26.04.1 as the server. I had to configure DHCP, DNS, HTTP, and SSH servers. For the server to function as a DHCP server, you must first set a static IP address, which would be 192.168.10.10.

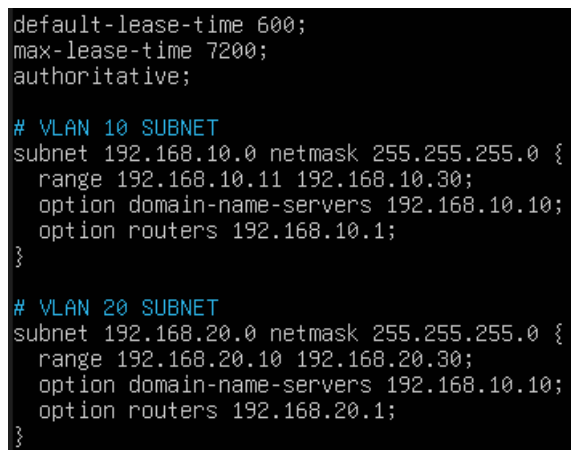


```

GNU nano 8.7.1
# This is the network config written by 'subiquity'
network:
  ethernets:
    enp0s3:
      addresses:
        - 192.168.10.10/24
      routes:
        - to: 0.0.0.0/0
          via: 192.168.10.1_
  version: 2

```

I installed the “isc-dhcp-server” DHCP server. Next, you need to edit the configuration file at “/etc/dhcp/dhcpd.conf.” As we mentioned earlier, the server is located in the DMZ, which is VLAN 10, and the internal LAN is VLAN 20. Since the router has a static IP address, addresses are assigned starting from 192.168.10.11.



```

default-lease-time 600;
max-lease-time 7200;
authoritative;

# VLAN 10 SUBNET
subnet 192.168.10.0 netmask 255.255.255.0 {
  range 192.168.10.11 192.168.10.30;
  option domain-name-servers 192.168.10.10;
  option routers 192.168.10.1;
}

# VLAN 20 SUBNET
subnet 192.168.20.0 netmask 255.255.255.0 {
  range 192.168.20.10 192.168.20.30;
  option domain-name-servers 192.168.10.10;
  option routers 192.168.20.1;
}

```

For the DNS server, I used “bind9.” The DNS server is configured by creating a configuration file in the /etc/bind folder; in this case, “db.corporationcom”.

```
GNU nano 8.7.1
$TTL      86400
@         IN      SOA      ns.corporation.com. root.corporation.com. (
        2      ; Serial
        3600   ; Refresh
        1800   ; Retry
        604800 ; Expire
        86400  ) ; Minimum TTL

@         IN      NS       ns.corporation.com
@         IN      A        192.168.10.10
ns        IN      A        192.168.10.10
www       IN      A        192.168.10.10
web       IN      CNAME    www
```

Unfortunately, I forgot to take screenshots of the HTTP server configuration—I used Apache2—but it was a very straightforward setup with a very simple index.html file; I also created a few more folders to perform a directory enumeration. Here are the screenshots showing the services running correctly.

```
administrator@corp-server:~$ service isc-dhcp-server status
• isc-dhcp-server.service - ISC DHCP IPv4 server
   Loaded: loaded (/usr/lib/systemd/system/isc-dhcp-server.service; enabled; preset: enabled)
   Active: active (running) since Sat 2026-09-05 10:21:48 UTC; 1h 0min ago
  Invocation: e1ee191f561f457888295d1212fa9717
     Docs: man:dhcpd(8)
    Main PID: 1269 (dhcpd)
      Tasks: 1 (limit: 1885)
     Memory: 6M (peak: 6.2M)
        CPU: 204ms
    CGroup: /system.slice/isc-dhcp-server.service
            └─1269 dhcpd -user dhcpd -group dhcpd -f -4 -pf /run/dhcp-server/dhcpd.pid -cf /etc/dhcp/dhcpd.conf enp0s3

Sep 05 10:21:48 corp-server dhcpd[1269]: PID file: /run/dhcp-server/dhcpd.pid
Sep 05 10:21:48 corp-server dhcpd[1269]: Wrote 2 leases to leases file.
Sep 05 10:21:48 corp-server sh[1269]: Wrote 2 leases to leases file.
Sep 05 10:21:48 corp-server dhcpd[1269]: Listening on LPF/enp0s3/08:00:27:f5:67:fa/192.168.10.0/24
Sep 05 10:21:48 corp-server sh[1269]: Listening on LPF/enp0s3/08:00:27:f5:67:fa/192.168.10.0/24
Sep 05 10:21:48 corp-server sh[1269]: Sending on LPF/enp0s3/08:00:27:f5:67:fa/192.168.10.0/24
Sep 05 10:21:48 corp-server sh[1269]: Sending on Socket/fallback/fallback-net
Sep 05 10:21:48 corp-server dhcpd[1269]: Sending on LPF/enp0s3/08:00:27:f5:67:fa/192.168.10.0/24
Sep 05 10:21:48 corp-server dhcpd[1269]: Sending on Socket/fallback/fallback-net
Sep 05 10:21:48 corp-server dhcpd[1269]: Server starting service.
administrator@corp-server:~$
```

```
administrator@corp-server:~$ service bind9 status
• named.service - BIND Domain Name Server
   Loaded: loaded (/usr/lib/systemd/system/named.service; enabled; preset: enabled)
   Active: active (running) since Sat 2026-09-05 10:19:50 UTC; 1h 1min ago
  Invocation: 3ba605aae61c4192976ccf5929c1da3e
     Docs: man:named(8)
    Main PID: 998 (named)
      Status: "running"
      Tasks: 8 (limit: 1885)
     Memory: 14.5M (peak: 14.7M)
        CPU: 351ms
    CGroup: /system.slice/named.service
            └─998 /usr/sbin/named -f -u bind

Sep 05 10:19:50 corp-server named[998]: configuring command channel from '/etc/bind/rndc.key'
Sep 05 10:19:50 corp-server named[998]: command channel listening on ::1#953
Sep 05 10:19:50 corp-server named[998]: managed-keys-zone: loaded serial 10
Sep 05 10:19:50 corp-server named[998]: zone corporation.com/IN: loaded serial 2
Sep 05 10:19:50 corp-server systemd[1]: Started named.service - BIND Domain Name Server.
Sep 05 10:19:50 corp-server named[998]: all zones loaded
Sep 05 10:19:50 corp-server named[998]: FIPS mode is disabled
Sep 05 10:19:50 corp-server named[998]: running
Sep 05 10:19:51 corp-server named[998]: managed-keys-zone: Key 20326 for zone . is now trusted (acceptance timer complete)
Sep 05 10:19:51 corp-server named[998]: managed-keys-zone: Key 38696 for zone . is now trusted (acceptance timer complete)
administrator@corp-server:~$
```

```

administrator@corp-server:~$ service apache2 status
• apache2.service - The Apache HTTP Server
  Loaded: loaded (/usr/lib/systemd/system/apache2.service; enabled; preset: enabled)
  Active: active (running) since Sat 2026-09-05 10:21:49 UTC; 1h 0min ago
  Invocation: 574f2da03c524d6491e330175937439f
  Docs: https://httpd.apache.org/docs/2.4/
  Main PID: 1273 (apache2)
  Status: "Total requests: 0; Idle/Busy workers 100/0; Requests/sec: 0; Bytes served/sec: 0 B/sec"
  Tasks: 55 (limit: 1885)
  Memory: 8.2M (peak: 8.3M)
  CPU: 1.496s
  CGroup: /system.slice/apache2.service
          └─1273 /usr/sbin/apache2 -k start -DFOREGROUND
            └─1338 /usr/sbin/apache2 -k start -DFOREGROUND
              └─1339 /usr/sbin/apache2 -k start -DFOREGROUND

Sep 05 10:21:48 corp-server systemd[1]: Starting apache2.service - The Apache HTTP Server...
Sep 05 10:21:49 corp-server apachectl[1273]: AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using
Sep 05 10:21:49 corp-server systemd[1]: Started apache2.service - The Apache HTTP Server.
lines 1-18/18 (END)

```

I also set up an SSH service as a gateway for the attack.

```

administrator@corp-server:~$ sudo systemctl enable --now ssh
[sudo: authenticate] Password:
Synchronizing state of ssh.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable ssh
Created symlink '/etc/systemd/system/ssh.service' → '/usr/lib/systemd/system/ssh.service'.
Created symlink '/etc/systemd/system/multi-user.target.wants/ssh.service' → '/usr/lib/systemd/system/ssh.service'.
administrator@corp-server:~$ sudo systemctl status ssh
• ssh.service - OpenBSD Secure Shell server
  Loaded: loaded (/usr/lib/systemd/system/ssh.service; enabled; preset: enabled)
  Active: active (running) since Sat 2026-09-05 11:19:48 UTC; 8s ago
  Invocation: a6b36fa839254c529120b2322471be87
  TriggeredBy: • ssh.socket
  Docs: man:sshd(8)
        man:sshd_config(5)
  Process: 2754 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
  Main PID: 2757 (sshd)
  Tasks: 1 (limit: 1885)
  Memory: 1.4M (peak: 2M)
  CPU: 44ms
  CGroup: /system.slice/ssh.service
          └─2757 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

Sep 05 11:19:48 corp-server systemd[1]: Starting ssh.service - OpenBSD Secure Shell server...
Sep 05 11:19:48 corp-server sshd[2757]: Server listening on 0.0.0.0 port 22.
Sep 05 11:19:48 corp-server systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
Sep 05 11:19:48 corp-server sshd[2757]: Server listening on :: port 22.
administrator@corp-server:~$ sudo

```

After installing all the services on the server, I needed a way to monitor any security issues that might arise, so I installed Wazuh on a computer on the internal LAN (Ubuntu Desktop) to act as the manager, and the Wazuh agent on the server.

```

soc-manager@soc-manager:~$ curl -sO https://packages.wazuh.com/4.14/wazuh-install.sh && sudo bash ./wazuh-install.sh -a
04/09/2026 15:02:44 INFO: Starting Wazuh installation assistant. Wazuh version: 4.14.7
04/09/2026 15:02:44 INFO: Verbose logging redirected to /var/log/wazuh-install.log
04/09/2026 15:02:46 INFO: The recommended systems are: Red Hat Enterprise Linux 7, 8, 9; CentOS 7, 8; Amazon Linux 2; Amazon Linux 2023; Ubuntu 16.04, 18.04
04/09/2026 15:02:46 WARNING: The current system does not match with the list of recommended systems. The installation may not work properly.
04/09/2026 15:02:50 INFO: --- Dependencies ---
04/09/2026 15:02:50 INFO: Installing gawk.
04/09/2026 15:02:55 INFO: Verifying that your system meets the recommended minimum hardware requirements.
04/09/2026 15:02:55 INFO: Wazuh web interface port will be 443.
04/09/2026 15:03:02 INFO: --- Dependencies ---
04/09/2026 15:03:02 INFO: Installing apt-transport-https.
04/09/2026 15:03:05 INFO: Installing debhelper.
04/09/2026 15:03:27 INFO: Wazuh repository added.
04/09/2026 15:03:27 INFO: --- Configuration files ---
04/09/2026 15:03:27 INFO: Generating configuration files.
04/09/2026 15:03:28 INFO: Generating the root certificate.
04/09/2026 15:03:28 INFO: Generating Admin certificates.
04/09/2026 15:03:28 INFO: Generating Wazuh indexer certificates.
04/09/2026 15:03:28 INFO: Generating Filebeat certificates.
04/09/2026 15:03:28 INFO: Generating Wazuh dashboard certificates.
04/09/2026 15:03:29 INFO: Created wazuh-install-files.tar. It contains the Wazuh cluster key, certificates, and passwords necessary for installation.
04/09/2026 15:03:29 INFO: --- Wazuh indexer ---
04/09/2026 15:03:29 INFO: Starting Wazuh indexer installation.
04/09/2026 15:04:10 INFO: Wazuh indexer installation finished.
04/09/2026 15:04:10 INFO: Wazuh indexer post-install configuration finished.
04/09/2026 15:04:10 INFO: Starting service wazuh-indexer.
04/09/2026 15:04:24 INFO: Wazuh indexer service started.

```

5. ATTACK SIMULATION

To carry out the attack on the server, I used a Kali Linux virtual machine, version 2026.2. The simulation was based on the premise that the attacker had already gained access to the network where the server was located. Keep in mind that in the screenshots, there is a 6-hour time difference between Kali Linux and the server.

I began the attack by scanning the network to locate the server using "arp-scan." Two IP addresses appeared: the first was the server's, and the second belonged to another VM that was not part of the project but had connected to the server by mistake, so we ignored it.

```
(root@kali)-[~]
# arp-scan --localnet
Interface: eth0, type: EN10MB, MAC: 08:00:27:5a:87:bc, IPv4: 192.168.10.14
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.10.10    08:00:27:f5:67:fa    PCS Systemtechnik GmbH
192.168.10.12    08:00:27:cd:26:4c    PCS Systemtechnik GmbH

2 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.289 seconds (111.84 hosts/sec). 2 responded
```

Now that we have the server's IP address, we'll perform a port scan to identify the services it runs, their versions, and so on. Since I didn't need a lot of information and didn't need to be discreet, I used the "-p-" options to view all open ports, "-A" to identify the operating system and versions, and "-T5" to speed up the scan.

```
(root@kali)-[~]
# nmap -p- -A 192.168.10.10 -T5
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-10 04:23 -0400
Nmap scan report for 192.168.10.10
Host is up (0.0035s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.2p1 Ubuntu 2ubuntu3.6 (Ubuntu Linux; protocol 2.0)
53/tcp    open  domain   ISC BIND 9.20.24-1ubuntu0.3 (Ubuntu Linux)
| dns-nsid:
|_ bind.version: 9.20.24-1ubuntu0.3-Ubuntu
80/tcp    open  http     Apache httpd 2.4.66 ((Ubuntu))
|_ http-server-header: Apache/2.4.66 (Ubuntu)
|_ http-title: CORPORATION.COM - HOME
MAC Address: 08:00:27:F5:67:FA (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), Android 5 - 10 (Linux 3.4 - 3.18) (93%), Linux 2.6.32 (93%)
TV (Linux 4.9) (93%), Android 10 - 12 (Linux 4.14 - 4.19) (93%), Linux 5.10 - 5.19 (93%), Nintendo Switch
, Linux 5.4 - 5.10 (93%), OpenWrt 21.02 (Linux 5.4) (93%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   3.54 ms  192.168.10.10

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 36.25 seconds
```

Since it appears there is an SSH service running on port 22, I made an initial brute-force attempt using the Hydra tool with the username "admin" to see how the information appears in Wazuh. I narrowed down the rockyou.txt list a bit so it would run more smoothly. It didn't work because OpenSSH has built-in protection against brute-force attacks, and since I used the "-T4" option,

multiple connections were attempted simultaneously, causing the service to start rejecting them. Fortunately, some of them were logged by Wazuh.

```
(kali㉿kali)-[~]
$ hydra -l admin -P rockyou1.txt 192.168.10.10 ssh -t4
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service
this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-10 04:27:23
[DATA] max 4 tasks per 1 server, overall 4 tasks, 100 login tries (l:1/p:100), ~25 tries per task
[DATA] attacking ssh://192.168.10.10:22/
[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
[INFO] Writing restore file because 2 server scans could not be completed
The session file ./hydra.restore was written. Type "hydra -R" to resume session.
[ERROR] 1 target was disabled because of too many errors
[ERROR] 1 targets did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-10 04:28:04
```

Threat Hunting					
153 hits					
Sep 9, 2026 @ 10:31:11.207 - Sep 10, 2026 @ 10:31:11.207					
Export Formatted Reset view 622 available fields Columns Density 1 fields sorted Full screen					
timestamp	agent.name	rule.description	rule.level	rule.id	
Sep 10, 2026 @ 10:28:05.1...	corp-server	sshd: Attempt to login using a non-existent user	5	5710	
Sep 10, 2026 @ 10:28:05.1...	corp-server	syslog: User missed the password more than one time	10	2502	
Sep 10, 2026 @ 10:28:05.1...	corp-server	Maximum authentication attempts exceeded.	8	5758	
Sep 10, 2026 @ 10:28:05.1...	corp-server	sshd: Attempt to login using a non-existent user	5	5710	
Sep 10, 2026 @ 10:28:03.1...	corp-server	syslog: User missed the password more than one time	10	2502	
Sep 10, 2026 @ 10:28:03.1...	corp-server	Maximum authentication attempts exceeded.	8	5758	
Sep 10, 2026 @ 10:28:03.1...	corp-server	sshd: Attempt to login using a non-existent user	5	5710	
Sep 10, 2026 @ 10:28:03.1...	corp-server	sshd: Attempt to login using a non-existent user	5	5710	
Sep 10, 2026 @ 10:28:01.1...	corp-server	syslog: User missed the password more than one time	10	2502	
Sep 10, 2026 @ 10:28:01.1...	corp-server	syslog: User missed the password more than one time	10	2502	
Sep 10, 2026 @ 10:28:01.1...	corp-server	sshd: Attempt to login using a non-existent user	5	5710	
Sep 10, 2026 @ 10:28:01.1...	corp-server	Maximum authentication attempts exceeded.	8	5758	
Sep 10, 2026 @ 10:28:01.1...	corp-server	sshd: Attempt to login using a non-existent user	5	5710	
Sep 10, 2026 @ 10:28:01.1...	corp-server	Maximum authentication attempts exceeded.	8	5758	
Sep 10, 2026 @ 10:28:01.0...	corp-server	sshd: Attempt to login using a non-existent user	5	5710	

Since HTTP servers are often an entry point and sometimes provide some clues, I proceed to enumerate the directories using Gobuster and the common.txt list, identifying three interesting directories: admin, backup, and uploads.

```
(kali㉿kali)-[~]
$ gobuster dir -u 192.168.10.10 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.10.10
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 318]
.htaccess (Status: 403) [Size: 318]
.htpasswd (Status: 403) [Size: 318]
admin (Status: 301) [Size: 354] [→ http://192.168.10.10/admin/]
backup (Status: 301) [Size: 355] [→ http://192.168.10.10/backup/]
index.html (Status: 200) [Size: 580]
server-status (Status: 403) [Size: 318]
uploads (Status: 301) [Size: 356] [→ http://192.168.10.10/uploads/]
Progress: 4613 / 4613 (100.00%)

Finished
```

Wazuh also displays a list of directories. In the alert details, you can see the requests that were sent to the server to retrieve the directories. Furthermore, the fact that “gobuster” appears as the User-Agent in the requests also gives us a clue that we are under attack.

W. Threat Hunting

API default

a

12:0015:0018:0021:0000:0003:0006:0009:00

timestamp per 30 minutes

8,873 hits

Sep 9, 2026 @ 10:34:54.839 - Sep 10, 2026 @ 10:34:54.839

Export FormattedReset view622 available fieldsColumnsDensity1 fields sortedFull screen

timestamp	agent.name	rule.description	rule.level	rule.id
Sep 10, 2026 @ 10:34:43.7...	corp-server	Web server 400 error code.	5	31101
Sep 10, 2026 @ 10:34:43.7...	corp-server	Web server 400 error code.	5	31101
Sep 10, 2026 @ 10:34:43.7...	corp-server	Web server 400 error code.	5	31101
Sep 10, 2026 @ 10:34:43.7...	corp-server	Web server 400 error code.	5	31101
Sep 10, 2026 @ 10:34:43.7...	corp-server	Web server 400 error code.	5	31101
Sep 10, 2026 @ 10:34:43.7...	corp-server	Web server 400 error code.	5	31101
Sep 10, 2026 @ 10:34:43.7...	corp-server	Web server 400 error code.	5	31101
Sep 10, 2026 @ 10:34:43.7...	corp-server	Web server 400 error code.	5	31101
Sep 10, 2026 @ 10:34:43.7...	corp-server	Multiple web server 400 error codes from same source ip.	10	31151
Sep 10, 2026 @ 10:34:43.7...	corp-server	Web server 400 error code.	5	31101
Sep 10, 2026 @ 10:34:43.7...	corp-server	Web server 400 error code.	5	31101
Sep 10, 2026 @ 10:34:43.7...	corp-server	Web server 400 error code.	5	31101
Sep 10, 2026 @ 10:34:43.7...	corp-server	Web server 400 error code.	5	31101
Sep 10, 2026 @ 10:34:43.7...	corp-server	Web server 400 error code.	5	31101
Sep 10, 2026 @ 10:34:43.7...	corp-server	Web server 400 error code.	5	31101
Sep 10, 2026 @ 10:34:43.7...	corp-server	Web server 400 error code.	5	31101

Rows per page: 15

<12345...592>

W. Discover

wazuh-alerts-4.x-2026.09.10#IA10iqABNtMG63fagDch

TableJSON

@timestamp

Sep 10, 2026 @ 10:34:43.771

_index

wazuh-alerts-4.x-2026.09.10

agent.id

001

agent.ip

192.168.10.10

agent.name

corp-server

data.id

404

data.protocol

GET

data.srcip

192.168.10.14

data.url

/zoeken

decoder.name

web-accesslog

full_log

192.168.10.14 - - [10/Sep/2026:10:34:29 +0200] "GET /zoeken HTTP/1.1" 404 476 "-" "gobuster/3.8.2"

id

1789029283.3497947

input.type

log

location

/var/log/apache2/access.log

manager.name

soc-manager

previous_output

> 192.168.10.14 - - [10/Sep/2026:10:34:29 +0200] "GET /xmlrpc_server.php HTTP/1.1" 404 476 "-" "gobuster/3.8.2"
192.168.10.14 - - [10/Sep/2026:10:34:29 +0200] "GET /zipfiles HTTP/1.1" 404 476 "-" "gobuster/3.8.2"
192.168.10.14 - - [10/Sep/2026:10:34:29 +0200] "GET /zorum HTTP/1.1" 404 476 "-" "gobuster/3.8.2"
192.168.10.14 - - [10/Sep/2026:10:34:29 +0200] "GET /zope HTTP/1.1" 404 476 "-" "gobuster/3.8.2"
192.168.10.14 - - [10/Sep/2026:10:34:29 +0200] "GET /zimbra HTTP/1.1" 404 476 "-" "gobuster/3.8.2"
192.168.10.14 - - [10/Sep/2026:10:34:29 +0200] "GET /zones HTTP/1.1" 404 476 "-" "gobuster/3.8.2"
192.168.10.14 - - [10/Sep/2026:10:34:29 +0200] "GET /zin HTTP/1.1" 404 476 "-" "gobuster/3.8.2"

rule.description

Multiple web server 400 error codes from same source ip.

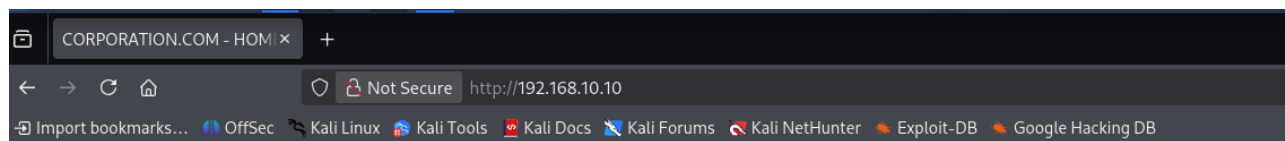
rule.firedtimes

293

rule.frequency

14

Now that we have the Apache server directories, let's check what's in them. I'll start by checking the index.html file to see what appears, and in the first directory I check (/admin), I find a secret.txt file that says we should delete a supposed test user (testuser).



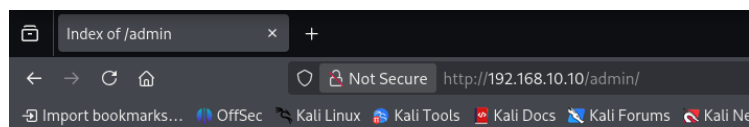
Welcome to corporation.com

This is the official internet web server for the corporation network.

System Status

- Network: Internal Isolated Lab
- Services: DHCP, DNS (BIND9), and Apache running
- Security Monitoring: Wazuh Agent Active

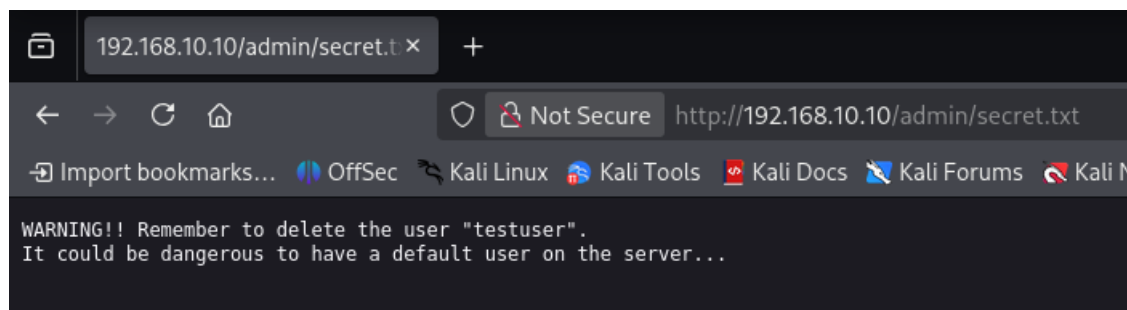
If you are performin security assesments or enumeration exercises, please ensure authorization is in place.



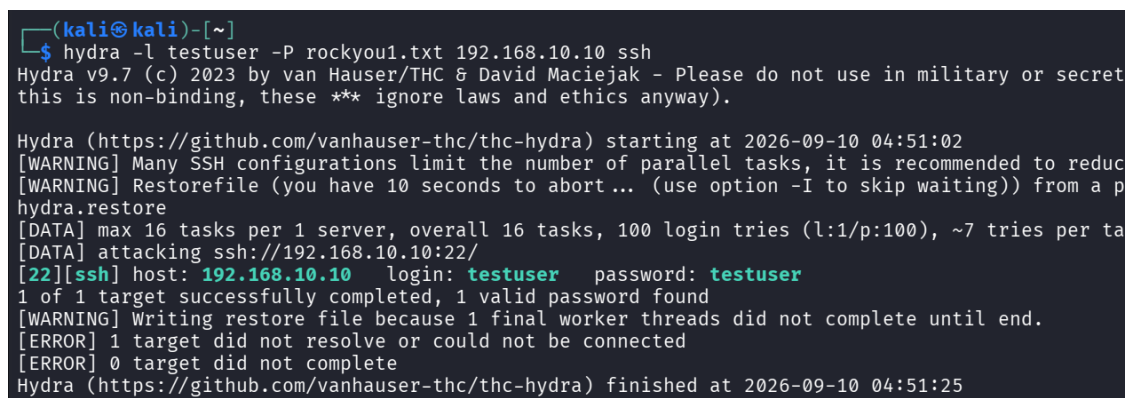
Index of /admin

Name	Last modified	Size	Description
Parent Directory	-	-	-
secret.txt	2026-09-05 20:05	112	-

Apache/2.4.66 (Ubuntu) Server at 192.168.10.10 Port 80



Once we had obtained a username, we repeated the brute-force attack on the SSH service, including that username in the edited list, in case it was used as the password. I forgot to add the “-T1” option so the attack wouldn’t fail, but since I had added “testuser” to the beginning of the list, it did manage to obtain the credentials.



In Wazuh, this event is a high-severity alert (level 12 or higher), as can be seen in the “Threat Hunting” section of the dashboard. In the log, we can verify that this is an SSH connection from the IP address 192.168.10.14 using the username “testuser” and that the connection occurred on port 51618. The alert description is “Multiple authentication failures followed by a successful login,” which accurately describes how Hydra operates. In the alert details, Wazuh also maps the event to the Mitre ATT&CK framework and provides the tactics and techniques the attacker may be following and using, along with the technique ID.

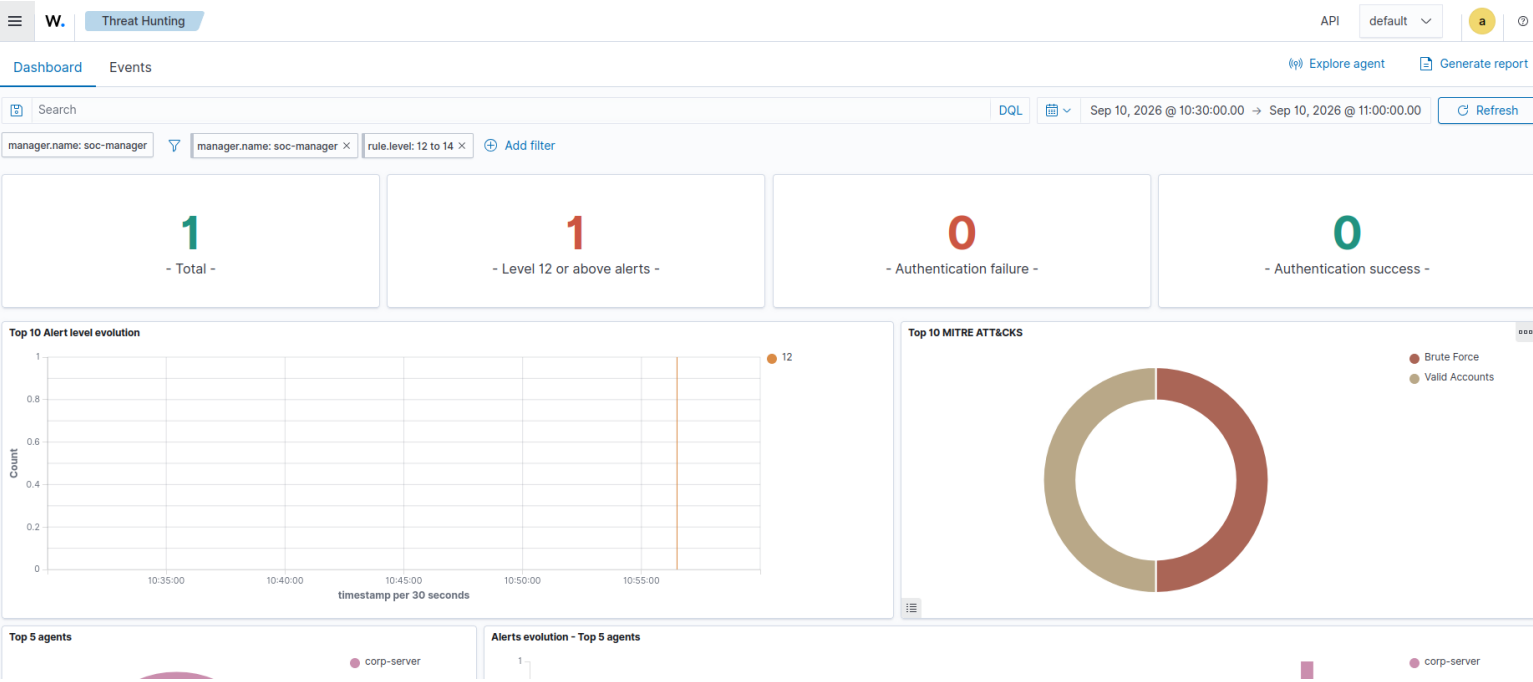


Table JSON

@timestamp	Sep 10, 2026 @ 10:56:49.186
_index	wazuh-alerts-4.x-2026.09.10
agent.id	001
agent.ip	192.168.10.10
agent.name	corp-server
data.dstuser	testuser
data.srcip	192.168.10.14
data.srcport	51618
decoder.name	sshd
decoder.parent	sshd
full_log	Sep 10 08:56:46 corp-server sshd-session[12752]: Accepted password for testuser from 192.168.10.14 port 51618 ssh2
id	1789030609.5523798
input.type	log
location	journald
manager.name	soc-manager
predecoder.hostname	corp-server
predecoder.program_name	sshd-session
predecoder.timestamp	Sep 10 08:56:46
rule.description	Multiple authentication failures followed by a success.
# rule.firedtimes	1
# rule.frequency	2
rule.gdpr	IV_35.7.d, IV_32.2
rule.gpg13	7.1, 7.8
rule.groups	syslog, attacks
rule.hipaa	164.312.b
rule.id	40112
# rule.level	12
rule.mail	true
rule.mitre.id	T1078, T1110
rule.mitre.tactic	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Credential Access
rule.mitre.technique	Valid Accounts, Brute Force
rule.nist_800_53	AU.14, AC.7, SI.4
rule.pci_dss	10.2.4, 10.2.5, 11.4
rule.tsc	CC6.1, CC6.8, CC7.2, CC7.3
timestamp	Sep 10, 2026 @ 10:56:49.186

I continued the attack by initiating an SSH connection using the "testuser" credentials. I also found this in Wazuh. The alert details show once again that the connection originated from the Kali Linux IP address, that the connection was made via interactive keyboard for the "testuser" account (meaning the password was typed in), and that the connection was made on port 43528.

```
(root@kali)-[/home/kali]
# ssh testuser@192.168.10.10
The authenticity of host '192.168.10.10 (192.168.10.10)' can't be established.
ED25519 key fingerprint is: SHA256:QZVpdZtXVYLHjYdxGEUS+EZIUHL75oq5YwCtpeLdbM
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.10.10' (ED25519) to the list of known hosts.
(testuser@192.168.10.10) Password:
Welcome to Ubuntu 26.04.1 LTS (GNU/Linux 7.0.0-31-generic x86_64)

 * Documentation:  https://docs.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Tue Sep 22 07:55:53 PM CEST 2026

System load:          0.19
Usage of /:            36.1% of 9.75GB
Memory usage:         24%
Swap usage:           0%
Processes:            140
Users logged in:      0
```

```
IPv4 address for enp0s8: 10.0.3.15
IPv6 address for enp0s8: fd17:625c:f037:3:a00:27ff:fe01:828f

 * Canonical Workshop gives developers fast, composable, reproducible, and
   secure developer environments that are perfect for agentic workflows.

   https://ubuntu.com/workshop

Expanded Security Maintenance for Applications is not enabled.

3 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Sat Sep  5 20:38:03 2026 from 192.168.10.14
dircolors: /home/testuser/.dir_colors: No such file or directory (os error 2)
testuser@corp-server:~$
```

W.

Threat Hunting

API default a

Dashboard

Events

Explore agent

Search

DQL

Sep 21, 2026 @ 19:58:37.230 → now

Refresh

manager.name: soc-manager

manager.name: soc-manager

Add filter

Count

timestamp per 30 minutes

69 hits

Sep 21, 2026 @ 19:58:37.230 - Sep 22, 2026 @ 19:58:45.551

Export Formatted Reset view 627 available fields Columns Density 1 fields sorted Full screen

timestamp	agent.name	rule.description	rule.level	rule.id
Sep 22, 2026 @ 19:56:03.9...	corp-server	PAM: Login session opened.	3	5501
Sep 22, 2026 @ 19:56:03.9...	corp-server	PAM: Login session opened.	3	5501
Sep 22, 2026 @ 19:56:03.9...	corp-server	sshd: authentication success.	3	5715

Table JSON

@timestamp	Sep 22, 2026 @ 19:56:03.917
t _index	wazuh-alerts-4.x-2026.09.22
t agent.id	001
t agent.ip	192.168.10.10
t agent.name	corp-server
t data.dstuser	testuser
t data.srcip	192.168.10.14
t data.srcport	43528
t decoder.name	sshd
t decoder.parent	sshd
t full_log	Sep 22 17:55:52 corp-server sshd-session[2589]: Accepted keyboard-interactive/pam for testuser from 192.168.10.14 port 43528 ssh2
t id	1790099763.26854
t input.type	log
t location	journald
t manager.name	soc-manager
t predecoder.hostname	corp-server
t predecoder.program_name	sshd-session
t predecoder.timestamp	Sep 22 17:55:52
t rule.description	sshd: authentication success.
# rule.firedtimes	1
t rule.gdpr	IV_32.2
t rule.gpg13	7.1, 7.2
t rule.groups	syslog, sshd, authentication_success
t rule.hipaa	164.312.b
t rule.id	5715
# rule.level	3
🕒 rule.mail	false
t rule.mitre.id	T1078, T1021
t rule.mitre.tactic	Defense Evasion, Persistence, Privilege Escalation, Initial Access, Lateral Movement
t rule.mitre.technique	Valid Accounts, Remote Services
t rule.nist_800_53	AU.14, AC.7
t rule.pci_dss	10.2.5
t rule.tsc	CC6.8, CC7.2, CC7.3
@timestamp	Sep 22, 2026 @ 19:56:03.917

To finish the attack, I check the permissions for “testuser,” who has been mistakenly granted full permissions, so I simply need to switch to the root user and look for flag.txt in their /home directory.

```

testuser@corp-server:~$ whoami
testuser
testuser@corp-server:~$ sudo -l
User testuser may run the following commands on corp-server:
  (ALL : ALL) NOPASSWD: ALL
testuser@corp-server:~$ sudo su
root@corp-server:/home/testuser# ls -l
total 0
root@corp-server:/home/testuser# cd ..
root@corp-server:/home# ls
administrator  flag.txt  testuser
root@corp-server:/home# cat flag.txt
You have compromised this server. Congrats!
root@corp-server:/home#

```

6. HARDENING

Since we have already simulated the attack, we are going to harden the server so that it cannot be attacked again. I have started by blocking password-based access to the SSH server so that connections are only possible using public keys.

```

GNU nano 8.7.1 /etc/ssh/sshd_config *
#LogLevel INFO

# Authentication:

#LoginGraceTime 2m
#PermitRootLogin prohibit-password
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10

PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future.
#AuthorizedKeysFile .ssh/authorized_keys .ssh/authorized_keys2

#AuthorizedPrincipalsFile none

#AuthorizedKeysCommand none
#AuthorizedKeysCommandUser nobody

# For this to work you will also need host keys in /etc/ssh/ssh_known_hosts
#HostbasedAuthentication no
# Change to yes if you don't trust ~/.ssh/known_hosts for
# HostbasedAuthentication
#IgnoreUserKnownHosts no
# Don't read the user's ~/.rhosts and ~/.shosts files
#IgnoreRhosts yes

# To disable tunneled clear text passwords, change to "no" here!
PasswordAuthentication no
#PermitEmptyPasswords no

# Change to "yes" to enable keyboard-interactive authentication. Depending on
# the system's configuration, this may involve passwords, challenge-response,
# one-time passwords or some combination of these and other methods.
# Beware issues with some PAM modules and threads.
KbdInteractiveAuthentication no

# Kerberos options

```

When I restart the SSH server to apply the configuration, I cut off the attacker's connection. I also verify that I can no longer access the server with the password.

```

administrator@corp-server:~$ sudo systemctl daemon-reload
administrator@corp-server:~$ sudo systemctl restart ssh.socket
Job failed. See "journalctl -xe" for details.
administrator@corp-server:~$ sudo systemctl stop ssh.socket
administrator@corp-server:~$ sudo systemctl restart ssh
administrator@corp-server:~$ sudo systemctl status ssh
• ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; enabled; preset: enabled)
   Active: active (running) since Tue 2026-09-22 20:47:11 CEST; 6s ago
  Invocation: 86c2571c931e427bab597faeba897064
     Docs: man:sshd(8)
           man:sshd_config(5)
   Process: 3626 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
  Main PID: 3629 (sshd)
    Tasks: 1 (limit: 1888)
   Memory: 1.3M (peak: 2.2M)
      CPU: 35ms
   CGroup: /system.slice/ssh.service
           └─3629 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

Sep 22 20:47:10 corp-server systemd[1]: Starting ssh.service - OpenBSD Secure Shell server..
Sep 22 20:47:11 corp-server sshd[3629]: Server listening on 0.0.0.0 port 22.
Sep 22 20:47:11 corp-server sshd[3629]: Server listening on :: port 22.
Sep 22 20:47:11 corp-server systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
administrator@corp-server:~$

```

```

root@corp-server:/home# ls
administrator  flag.txt  testuser
root@corp-server:/home# cat flag.txt
You have compromised this server. Congrats!
root@corp-server:/home# Connection to 192.168.10.10 closed by remote host.
Connection to 192.168.10.10 closed.

```

```

└─(root@kali)-[/home/kali]
# █

```

```

└─(root@kali)-[/home/kali]
# ssh testuser@192.168.10.10
testuser@192.168.10.10: Permission denied (publickey).

```

```

└─(root@kali)-[/home/kali]
# █

```

Next, I changed the SSH server port from 22 to 2222.

```

# For changes to take effect, run:
#
#   systemctl daemon-reload
#   systemctl restart ssh.socket
#
Port 2222_
#AddressFamily any
#ListenAddress 0.0.0.0
#ListenAddress ::

#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key

```

To prevent the “testuser” account from being used again, I delete it along with all its folders and verify that the deletion was successful.

```

administrator@corp-server:~$ sudo userdel -r testuser
userdel: testuser mail spool (/var/mail/testuser) not found
administrator@corp-server:~$ cat /etc/passwd | grep testuser
administrator@corp-server:~$

```

```

administrator@corp-server:~$ sudo su
root@corp-server:/home/administrator# cd ..
root@corp-server:/home# ls
administrator  flag.txt
root@corp-server:/home# su - testuser
su: user testuser does not exist or the user entry does not contain all the required fields
root@corp-server:/home# _

```

Next, I checked the permissions each user had in the sudoers file and removed those for the “testuser” account.

```

# User privilege specification
root    ALL=(ALL:ALL) ALL
testuser ALL=(ALL:ALL) NOPASSWD: ALL

# Members of the admin group may gain root privileges
%admin   ALL=(ALL) ALL

# Allow members of group sudo to execute any command
%sudo   ALL=(ALL:ALL) ALL

# See sudoers(5) for more information on "@include" directives:

@includedir /etc/sudoers.d

```

```

# User privilege specification
root    ALL=(ALL:ALL) ALL

# Members of the admin group may gain root privileges
%admin   ALL=(ALL) ALL

# Allow members of group sudo to execute any command
%sudo   ALL=(ALL:ALL) ALL

# See sudoers(5) for more information on "@include" directives:

@include /etc/sudoers.d

```

I also established some rules for creating and changing passwords. Now, passwords must be changed every 90 days, with a minimum interval of 7 days between changes and 14 days’ notice before the change. I installed “pam_pwquality” and edited the configuration file /etc/pam.d/common-password to enforce complex passwords—with a minimum length of 12 characters and including one uppercase letter, one lowercase letter, one number, and one special character—even for the root user. Afterward, I verified that the configuration was working as intended.

```

#
# Password aging controls:
#
#     PASS_MAX_DAYS   Maximum number of days a password may be used.
#     PASS_MIN_DAYS   Minimum number of days allowed between password changes.
#     PASS_WARN_AGE   Number of days warning given before a password expires.
#
PASS_MAX_DAYS   90
PASS_MIN_DAYS    7
PASS_WARN_AGE   14
#

```

```

GNU nano 8.7.1 /etc/pam.d/common-password *
#
# /etc/pam.d/common-password - password-related modules common to all services
#
# This file is included from other service-specific PAM config files,
# and should contain a list of modules that define the services to be
# used to change user passwords. The default is pam_unix.
#
# Explanation of pam_unix options:
# The "yescrypt" option enables
# hashed passwords using the yescrypt algorithm, introduced in Debian
# 11. Without this option, the default is Unix crypt. Prior releases
# used the option "sha512"; if a shadow password hash will be shared
# between Debian 11 and older releases replace "yescrypt" with "sha512"
# for compatibility. The "obscure" option replaces the old
# OBSOLETE_CHECKS_ENAB option in login.defs. See the pam_unix manpage
# for other options.
#
# As of pam 1.0.1-6, this file is managed by pam-auth-update by default.
# To take advantage of this, it is recommended that you configure any
# local modules either before or after the default block, and use
# pam-auth-update to manage selection of other modules. See
# pam-auth-update(8) for details.
#
# here are the per-package modules (the "Primary" block)
password      requisite      pam_pwquality.so retry=3 minlen=12 ucredit=-1 lcredit=-1 dcredit=-1 ocredit=-1 enforce_for_root
password      [success=1 default=ignore] pam_unix.so obscure yescrypt
# here's the fallback if no module succeeds
password      requisite      pam_deny.so
# prime the stack with a positive return value if there isn't one already;
# this avoids us returning an error just because nothing sets a success code
# since the modules above will each just jump around
password      required      pam_permit.so
# and here are more per-package modules (the "Additional" block)
# end of pam-auth-update config

```

```

administrator@corp-server:/home$ sudo passwd administrator
New password:
BAD PASSWORD: The password contains less than 1 digits
New password:
BAD PASSWORD: The password contains less than 1 digits
New password:
BAD PASSWORD: The password contains the user name in some form
passwd: Have exhausted maximum number of retries for service
passwd: password unchanged
administrator@corp-server:/home$ sudo passwd administrator
New password:
Retype new password:
passwd: password updated successfully
administrator@corp-server:/home$ _

```

And finally, I set up iptables to control connections to the server. The idea was to secure the SSH server by limiting connection attempts and thus prevent further brute-force attacks, but also to close all ports that weren't necessary for the server to function properly. I broke them down into sections to make them easier to see in the screenshot; you don't actually need to do that. Keep in mind that iptables rules are read as a list from top to bottom.

```

administrator@corp-server:~$ sudo iptables -P INPUT DROP
administrator@corp-server:~$ sudo iptables -P FORWARD DROP
administrator@corp-server:~$ sudo iptables -P OUTPUT ACCEPT
administrator@corp-server:~$ sudo iptables -A INPUT -i lo -j ACCEPT
administrator@corp-server:~$ sudo iptables -A INPUT -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
administrator@corp-server:~$ sudo iptables -A INPUT -p tcp --dport 2222 -m state --state NEW -m recent --set --name SSH_ATTACK
administrator@corp-server:~$ sudo iptables -A INPUT -p tcp --dport 2222 -m state --state NEW -m recent --update --seconds 60 --hitcount 3 --name SSH_ATTACK -j DROP
administrator@corp-server:~$ sudo iptables -A INPUT -p tcp --dport 2222 -j ACCEPT
administrator@corp-server:~$ sudo iptables -A INPUT -p tcp --dport 80 -j ACCEPT
administrator@corp-server:~$ sudo iptables -A INPUT -p tcp --dport 443 -j ACCEPT
administrator@corp-server:~$ sudo iptables -A INPUT -p tcp --dport 53 -j ACCEPT
administrator@corp-server:~$ sudo iptables -A INPUT -p udp --dport 53 -j ACCEPT
administrator@corp-server:~$ sudo iptables -A INPUT -p udp --dport 67 --dport 68 -j ACCEPT
iptables v1.8.11 (nf_tables): udp: option "--destination-port" can only be used once.
Try `iptables -h' or 'iptables --help' for more information.
administrator@corp-server:~$ sudo iptables -A INPUT -p udp --dport 67 -j ACCEPT
administrator@corp-server:~$ sudo iptables -A INPUT -p udp --dport 68 -j ACCEPT
administrator@corp-server:~$

```

Now let's explain the iptables rules:

- `sudo iptables -P INPUT DROP`
`sudo iptables -P FORWARD DROP`
`sudo iptables -P OUTPUT ACCEPT`

These iptables rules block all incoming traffic and forwarded traffic and allow outgoing traffic.

- `sudo iptables -A INPUT -i lo -j ACCEPT`
`sudo iptables -A INPUT -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT`

The first rule allows incoming traffic on the loopback interface because services sometimes communicate with themselves; otherwise, they would fail. The second rule allows already established connections so that the Wazuh agent installed on the server can maintain its connection with the manager after it starts up.

- `sudo iptables -A INPUT -p tcp --dport 2222 -m state --state NEW -m recent --set --name SSH_ATTACK`
`sudo iptables -A INPUT -p tcp --dport 2222 -m state --state NEW -m recent --update --seconds 60 --hitcount 3 --name SSH_ATTACK -j DROP`

These two iptables rules are used to prevent new brute-force attacks against the SSH server. They establish a policy for the maximum number of connection attempts per minute using iptables. The first rule logs the IP addresses attempting to open a new connection into a list called "SSH_ATTACK," while the second rule checks the list; if it finds an IP address that has attempted to connect more than 3 times in less than 60 seconds, the connection is rejected.

- `sudo iptables -A INPUT -p tcp --dport 2222 -j ACCEPT`
`sudo iptables -A INPUT -p tcp --dport 80 -j ACCEPT`
`sudo iptables -A INPUT -p tcp --dport 443 -j ACCEPT`
`sudo iptables -A INPUT -p tcp --dport 53 -j ACCEPT`
`sudo iptables -A INPUT -p udp --dport 53 -j ACCEPT`
`sudo iptables -A INPUT -p udp --dport 67 -j ACCEPT`
`sudo iptables -A INPUT -p udp --dport 68 -j ACCEPT`

All of these iptables rules are designed to allow incoming traffic only to the services running on the server: SSH, HTTP and HTTPS, DNS, and DHCP.

To save the iptables rules, you must install iptables-persistent. Otherwise, they would be lost when the server is shut down because, after they are created, they remain only in RAM.

```

(Reading database... 140856 files and directories currently installed.)
Removing ufw (0.36.2-9build1)...
Skip stopping firewall: ufw (not enabled)
Selecting previously unselected package netfilter-persistent.
(Reading database... 140763 files and directories currently installed.)
Preparing to unpack .../netfilter-persistent_1.0.24_all.deb...
Unpacking netfilter-persistent (1.0.24)...
Selecting previously unselected package iptables-persistent.
Preparing to unpack .../iptables-persistent_1.0.24_all.deb...
Unpacking iptables-persistent (1.0.24)...
Setting up netfilter-persistent (1.0.24)...
Created symlink '/etc/systemd/system/iptables.service' → '/usr/lib/systemd/system/netfilter-persistent.service'.
Created symlink '/etc/systemd/system/ip6tables.service' → '/usr/lib/systemd/system/netfilter-persistent.service'.
Created symlink '/etc/systemd/system/multi-user.target.wants/netfilter-persistent.service' → '/usr/lib/systemd/system/netfilter-persistent.service'.
Setting up iptables-persistent (1.0.24)...
Processing triggers for man-db (2.13.1-1build1)...
Scanning processes...
Scanning linux images...

Running kernel seems to be up-to-date.

No services need to be restarted.

No containers need to be restarted.

No user sessions are running outdated binaries.

No VM guests are running outdated hypervisor (qemu) binaries on this host.
administrator@corp-server:~$ sudo netfilter-persistent save
run-parts: executing /usr/share/netfilter-persistent/plugins.d/15-ip4tables save
run-parts: executing /usr/share/netfilter-persistent/plugins.d/25-ip6tables save
administrator@corp-server:~$

```

To secure the Apache server, I made the following configuration changes:

- I disabled the “Indexes” option in the /etc/apache2/apache2.conf file to prevent users from viewing files in a folder if there is no index.html file in that folder.

```

<Directory /var/www/>
    Options -Indexes +FollowSymLinks
    AllowOverride None
    Require all granted
</Directory>
_

```

- I installed Fail2ban to block directory traversal. The default configuration file is copied to prevent changes from being overwritten, and it is edited in /etc/fail2ban/jail.local. Each section is a “jail”; I edited the “apache-badbots” and “apache-noscript” jails. The first one detects crawlers that appear as User-Agent in the HTTP header and blocks them. The second one monitors the /etc/apache2/error.log file and detects and blocks IP addresses that receive too many errors during their searches.

```

[apache-badbots]
# Ban hosts which agent identifies spammer robots crawling the web
# for email addresses. The mail outputs are buffered.
enabled = yes
port    = http,https
logpath = /var/log/apache2/access.log
maxretry = 3_

[apache-noscript]
enabled = yes
port    = http,https
logpath = /var/log/apache2/error.log
maxretry = 5

```

7. HARDENING TEST

The first thing to check is whether the SSH server port has been successfully changed from 22 to 2222.

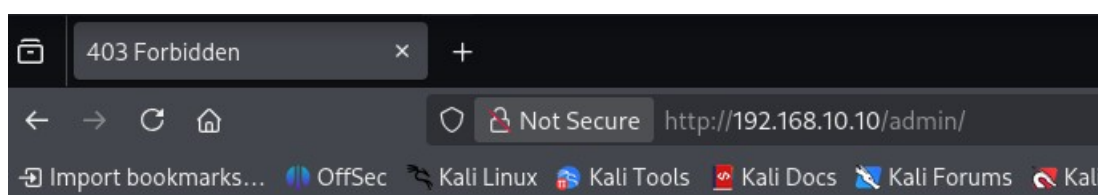
```
(root@kali)-[/home/kali]
# ssh testuser@192.168.10.10
^C
(root@kali)-[/home/kali]
# ssh testuser@192.168.10.10 -p2222
testuser@192.168.10.10: Permission denied (publickey).
```

Next, I wanted to try a brute-force attack to verify that the attacker's IP address was being blocked, but Hydra didn't work because of the password authentication block, so we treated the IP block based on failed attempts as a double safeguard.

```
(root@kali)-[/home/kali]
# hydra -l administrator -P rockyou1.txt 192.168.10.10 -s 2222 ssh -t1
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for
illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-28 11:24:39
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prev
ent overwriting, ./hydra.restore
[DATA] max 1 task per 1 server, overall 1 task, 100 login tries (l:1/p:100), ~100 tries per task
[DATA] attacking ssh://192.168.10.10:2222/
[ERROR] target ssh://192.168.10.10:2222/ does not support password authentication (method reply 4).
```

The next step would be to verify that the configuration to prevent exploitation of the HTTP server is working. The “-Indexes” setting does work, so the contents of the “/admin” folder—where the secrets.txt file was located—can no longer be accessed.



Forbidden

You don't have permission to access this resource.

Apache/2.4.66 (Ubuntu) Server at 192.168.10.10 Port 80

Unfortunately, Gobuster was able to enumerate the directories without any problems, so the directory scan block is not configured properly.

```
(root@kali)-[/home/kali]
└─$ gobuster dir -u 192.168.10.10 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2 (amd64) Server at 192.168.10.10 Port 80
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:          http://192.168.10.10
[+] Method:       GET
[+] Threads:      10
[+] Wordlist:      /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:    gobuster/3.8.2
[+] Timeout:      10s

Starting gobuster in directory enumeration mode

.htaccess      (Status: 403) [Size: 318]
.hta           (Status: 403) [Size: 318]
.htpasswd      (Status: 403) [Size: 318]
admin          (Status: 301) [Size: 354] [→ http://192.168.10.10/admin/]
backup         (Status: 301) [Size: 355] [→ http://192.168.10.10/backup/]
index.html     (Status: 200) [Size: 580]
server-status  (Status: 403) [Size: 318]
uploads        (Status: 301) [Size: 356] [→ http://192.168.10.10/uploads/]
Progress: 4613 / 4613 (100.00%)

Finished
```

After doing some research, it turns out that Fail2ban's default filters block outdated User-Agents and do not work with Gobuster, even if it appears in the request. To block enumeration attacks, you need to add a custom rule that monitors access logs to record the IP addresses that generate multiple requests with a 403 (Forbidden) or 404 (Page Not Found) status code. The custom rule "apache-custom.conf" is added as a file in the filters folder at "/etc/fail2ban/filter.d" and then added as a jail to the "jail.local" file.

```
GNU nano 8.7.1 /etc/fail2ban/filter.d/apache-custom.conf *
[Definition]
failregex = ^<HOST> .*"(GET|POST|HEAD) .*" (404|403)
ignoreregex =
```

```
[apache-custom]
enabled = true
port = http,https
logpath = /var/log/apache2/access.log
filter = apache-custom
maxretry = 3
bantime = 600
findtime = 60
```

With this new custom configuration, the Gobuster connection is rejected, thereby blocking directory enumeration.

```
(root@kali)-[/home/kali]
# gobuster dir -u 192.168.10.10 -w /usr/share/wordlists/dirb/common.txt
```

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

```
[+] Url: http://192.168.10.10
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
```

Starting gobuster in directory enumeration mode

Progress: 0 / 1 (0.00%)

2026/09/28 12:18:47 error on running gobuster on http://192.168.10.10/: connection refused

```
(root@kali)-[/home/kali]
#
```